

EGR6301 — Етичний хакінг

Лабораторна робота 5: Перелік сервісів та експлуатація невідомої цілі

Kioptrix Level 1 — Від розвідки до root-доступу

Факультет комп'ютерних технологій та кібербезпеки • Весна 2026

Тривалість:	100 хвилин
Всього:	100 балів
Цільова машина:	Kioptrix Level 1 (VulnHub)
Download:	https://www.vulnhub.com/entry/kioptrix-level-1-1,22/

ОБОВ'ЯЗКОВІ ПРАВИЛА ЗВІТУВАННЯ

Якщо ваш звіт містить лише вивід інструментів і скріншоти без вашого власного аналізу, ви отримаєте **НУЛЬ** балів за цей розділ. Кожен скріншот має супроводжуватися абзацом: **ЩО ви знайшли, ЧОМУ це важливо, ЩО далі.**

Ви **ПОВИННІ** задокументувати щонайменше одну реальну невдачу: скан без результатів, інструмент з помилкою, сервіс без відповіді, експлойт, який не спрацював. Опишіть що сталося, чому, і що ви зробили замість. AI-звіти майже ніколи не містять справжніх невдач. Звіт без невдач — це звіт не з реального досвіду.

Кожен студент повинен написати унікальне пояснення ланцюжка атаки власними словами: як одна знахідка призвела до наступної дії. Двоє студентів можуть виявити однакові сервіси, але жодні двоє не повинні описувати свій процес міркування ідентично.

Сценарій

Вас найняла невелика фінансова компанія як молодшого пентестера. Клієнт попросив вашу команду оцінити один із застарілих Linux-серверів, який нещодавно виявили у внутрішній мережі. Ніхто з IT-відділу не пам'ятає, коли сервер було розгорнуто і що на ньому працює. Ваші Правила проведення тестування (Rules of Engagement) дозволяють повну експлуатацію цього єдиного хоста. Сервер представлений як VM Kioptrix Level 1, яку ви розгорнете у VirtualBox поряд із вашою атакуючою машиною Kali Linux. На відміну від Metasploitable 2, з яким ви працювали весь семестр, це машина, яку ви раніше ніколи не бачили. Вам потрібно буде застосувати все, що ви вивчили на тижнях 1–4, щоб виявити сервіси, ідентифікувати вразливості та самостійно отримати root-доступ.

Рівні складності

Основний рівень (Core) охоплює частини 1–3 і є обов'язковим для всіх студентів. На його виконання потрібно приблизно 80 хвилин. Просунутий рівень (Advanced) у Частині 4 призначений для студентів, які завершили основну роботу і хочуть спробувати самостійну експлуатацію, розвиваючи навички з Лабораторної 3.

Част.	Опис	Вали	Час
1	Розгортання та розвідка	15	~15 хв
2	Ручний перелік	25	~30 хв
3	Ідентифікація вразл. та план	20	~25 хв
4 (Adv)	Експлуатація	20	~25 хв

Частина 1: Розгортання цілі та розвідка (Core)

(15 балів, приблизно 15 хвилин)

Перш ніж оцінювати ціль, потрібно розгорнути її та з'ясувати, що на ній є. Ця частина відтворює першу фазу будь-якого реального тестування: ви отримуєте діапазон мережі і повинні знайти свою ціль та скласти початковий перелік сервісів.

Завдання 1.1 — Розгортання VM (5 балів)

Завантажте образ VM Kioptrix Level 1 з VulnHub (або інструктор може надати його на USB-носії або у спільній папці). Імпортуйте його у VirtualBox. Налаштуйте мережевий адаптер на використання тієї ж мережі Host-Only, що й у вашій Kali VM. Завантажте обидві машини і переконайтеся, що вони можуть комунікувати. Зробіть скріншот, який показує успішний ping з Kali на IP-адресу Kioptrix. Якщо ви не можете визначити IP Kioptrix, використайте netdiscover або arp-scan. Зверніть увагу, що Kioptrix стара VM, і вам може знадобитися видалити та повторно додати мережевий адаптер у налаштуваннях VirtualBox, якщо вона не отримує IP через DHCP.

Завдання 1.2 — Початкова розвідка (10 балів)

Виконайте комплексне сканування цільової машини за допомогою Nmap. Зберіть щонайменше таку інформацію: усі відкриті TCP-порти, сервіс на кожному порту, версію кожного сервісу та припущення щодо операційної системи. Обирайте прапори сканування свідомо. Складіть таблицю сервісів зі стовпцями: Порт, Протокол, Стан, Сервіс, Версія. Таблиця повинна містити щонайменше 5 сервісів. Під таблицею напишіть короткий абзац (3–5 речень), у якому опишіть, що це за система на вашу думку, з якої епохи Linux вона, та що б ви досліджували далі.

Частина 2: Ручна взаємодія з сервісами та перелік (Core)

(30 балів, приблизно 35 хвилин)

Автоматичні сканери повідомляють, які порти відкриті. Ручна взаємодія показує, що сервіси насправді роблять і як поведуться. У цій частині ви вручну взаємодіятимете з кожним цікавим сервісом, як це робиться під час реального тестування перед запуском будь-якого експлойта.

Завдання 2.1 — Збір банерів за допомогою Netcat (12 балів)

Використайте Netcat для підключення щонайменше до трьох різних сервісів на ціль. Для кожного підключення запишіть точний банер або відповідь. Спробуйте SSH (порт 22), HTTP (порт 80) та щонайменше один додатковий сервіс на ваш вибір. Для HTTP сформууйте ручний GET-запит (GET / HTTP/1.0 та 2 Enter) і захопіть повні заголовки відповіді. Зверніть особливу увагу на заголовок Server, який на цій цілі розкриває не лише версію Apache, але й версію mod_ssl та OpenSSL в одному рядку. Порівняйте рядки версій Netcat із виводом Nmap для тих самих портів і зафіксуйте кожну розбіжність.

Завдання 2.2 — Перелік SMB (15 балів)

На ціль працюють SMB-сервіси на порту 139. Ваше завдання є витягти якомога більше інформації, використовуючи щонайменше три різні підходи. Спочатку smbclient з прапором -L та null-сесією. Потім enum4linux з прапором -a. Третім методом є Nmap-скрипти smb-enum-shares та smb-enum-users. Зведіть знахідки у структуроване резюме: які ресурси існують, чи є доступ без облікових даних, які користувачі виявлені, яка точна версія Samba? Останнє питання навмисно складне. Якщо перші три методи не виявили версію, спробуйте smbclient зі спостереженням за виводом протокольної угоди, або Metasploit-модуль auxiliary/scanner/smb/smb_version. Задokumentуйте кожен метод. Не витрачайте більше 15 хвилин на визначення версії.

Частина 3: Ідентифікація вразливостей та планування атаки (Core)

(20 балів, приблизно 25 хвилин)

Тепер у вас є детальне розуміння сервісів цілі. Наступний крок у методології пентестингу це зіставити сервіси з відомими вразливостями та побудувати план атаки. Це критичний міст між розвідкою та експлуатацією.

Завдання 3.1 — Автоматичне сканування вразливостей (8 балів)

Запустіть Nikto проти веб-сервера на порті 80 та окремо на порті 443. Запустіть Nmap з прапором --script vuln проти цілі. Захопіть вивід. Виділіть 3 найважливіші знахідки від кожного інструмента. Для кожної поясніть 1–2 реченнями, чому вона важлива. Одна знахідка Nikto повинна стосуватися застарілих версій Apache/mod_ssl, одна знахідка Nmap є вразливості SMB.

Завдання 3.2 — Зіставлення CVE та план атаки (12 балів)

Побудуйте таблицю поверхні атаки: сервіс і версія, ідентифікатор CVE, оцінка CVSS, наявність експлойта (так/ні, джерело), доавтентифікаційний доступ, надійність. Щонайменше 4 записи, що охоплюють щонайменше 3 різні сервіси. Kioptrix Level 1 має два відомі шляхи експлуатації: через Apache mod_ssl (CVE-2002-0082, відомий як OpenFuck) та через Samba (trans2open overflow, CVE-2003-0201). Обидва мають бути у вашій таблиці. Під таблицею напишіть план атаки як професійну нотатку.

Частина 4: Експлуатація (Advanced)

(20 балів, приблизно 25 хвилин)

У Лабораторній 3 ви виконували керовану експлуатацію vsftpd. Цього разу ніхто не скаже вам, який модуль використовувати. У вас є план атаки з частини 3. Виконайте його.

Завдання 4.1 — Отримання root-доступу (12 балів)

Експлуатуйте одну з вразливостей з частини 3. Можна використовувати Metasploit або окремий експлойт. Якщо обираєте Samba trans2open у Metasploit, зверніть увагу, що потрібно встановити payload linux/x86/shell_reverse_tcp за замовчуванням, оскільки старе ядро цілі не підтримує надійні staged payloads. Якщо обираєте mod_ssl, потрібно скомпілювати експлойт з вихідного коду (libssl-dev + правильний target offset). Задokumentуйте повний процес. Зробіть скріншот термінала з whoami, id, uname -a. Задokumentована невдача з подальшим успішним переходом оцінюється на повний бал.

Завдання 4.2 — Професійний Finding (8 балів)

Напишіть професійний Finding для експлуатованої вразливості. Включіть усі п'ять компонентів з Лабораторної 3: Назва з CVE, Докази (Evidence), Вплив (Impact) думайте ширше за 'root shell' (це фінансова компанія), Впевненість (Confidence), Рекомендації (Recommendation) з щонайменше 4 кроками. Знахідка має бути зрозумілою нетехнічному менеджеру.

Важливі примітки

Kioptrix Level 1 — стара VM (Red Hat Linux 7.2, прибіл. 2009). Якщо VirtualBox має проблеми з мережею, спробуйте видалити та повторно додати мережевий адаптер або перемикає між режимами NAT і Host-Only.

Версію Samba на Kioptrix навмисно складно визначити. Не витрачайте більше 15 хвилин. Задokumentуйте спроби і рухайтеся далі. Версія — Samba 2.2.1a, що можна підтвердити власними спробами.

Вся робота повинна виконуватися у вашому ізолюваному середовищі. Не скануйте машини за межами VirtualBox Host-Only.

Це індивідуальна робота. Вся експлуатація, аналіз та написання звіту повинні бути вашою власною роботою. Див. Розділ 6 силабусу.

Результат: Єдиний звіт, що містить усі завдання, скріншоти, таблиці та аналіз. Назвіть файл Lab5_Прізвище_Група.docx.

Здайте звіт до дедлайну.